

DPDP COMPLIANCE AUDIT

finance-data-processing

Digital Personal Data Protection Act 2023



Grade A — Strong

Scanned: 08 April 2026

Files indexed: 14

Languages: express, pg, bcryptjs, jsonwebtoken, express-validator, swagger-ui-express

CONFIDENTIAL — Internal Use Only

DPDP Compliance Scan Report

The application collects user credentials (email, password hash), user profile information (name, role), and financial transaction data (amount, category, date, notes). The primary DPDP risk lies in the potential for unauthorized access to sensitive financial transaction data and user credentials due to the lack of explicit consent mechanisms for data processing.

Total findings: 13

HIGH: 1

MEDIUM: 2

INFO: 4

PASS: 4

Tech Stack: express, pg, bcryptjs, jsonwebtoken, express-validator

Risk Profile: The application collects user credentials (email, password hash), user profile information (name, role), and financial transaction data (amount, category, date, notes). The primary DPDP risk lies in the potential for unauthorized access to sensitive financial transaction data and user credentials due to the lack of explicit consent mechanisms for data processing.

Compliance score by section

DPDP Section	Weight	Score	Status
Section 6	22	22/22 (100%)	PASS
Section 6(6)	8	8/8 (100%)	PASS
Section 8(1)	18	18/18 (100%)	PASS
Section 8	10	7.0/10 (70%)	WARN
Section 8(3)	8	8/8 (100%)	PASS
Section 8(4)	8	4.0/8 (50%)	WARN
Section 8(6)	8	6.8/8 (85%)	PASS
Section 9	6	6/6 (100%)	PASS
Section 11	6	6/6 (100%)	PASS
Section 16	4	4/4 (100%)	PASS
Section 5	2	2/2 (100%)	PASS
Section 13 — Grievance Redressal		0/4 (0%)	FAIL

Estimated Total Remediation Effort: 1.1–4.2 engineering days

Data Flow Analysis

The following PII flow signals were inferred via static analysis (import/call adjacency). These are heuristic code-path chains, not proven runtime traces. Use them to guide developer review (confirm actual request → handler → service → database paths in your app).

Flow 1: Application Logs

PII fields: password, email

auth.js → authController.js → database.js

Flow 2: Application Logs

PII fields: password, email, address

users.js → userController.js → database.js

Rule	Section	Severity	File
GRIEVANCE_OFFICER_MISSING	Section 13 — Grievance Redressal	HIGH	N/A
AUDIT_TRAIL_PARTIAL	Section 8(4) — Audit Trail	MEDIUM	N/A
INCOMPLETE_DELETION_COVERAGE	Section 8 — Data Principal Rights	MEDIUM	N/A
NO_BREACH_ALERTING	Section 8(6) — Breach	LOW	N/A
DATA_PORTABILITY_MISSING	Section 11 — Data Portability	LOW	N/A
INTERNAL_ROUTE_PII_ACCESS	Section 7 — Legitimate Use	INFO	src/routes/users.js
NO_THIRD_PARTY_DETECTED	Section 5 — Notice	INFO	N/A
NO_THIRD_PARTY_DATA_SHARING	Section 5 — Purpose Limitation	INFO	N/A
NO_CROSS_BORDER_DETECTED	Section 16 — Cross-Border Transfer	INFO	N/A
CONSENT_PRESENT	Section 6 — Consent	PASS	src/routes/auth.js
CONSENT_WITHDRAWAL_PRESENT	Section 6(6) — Consent Withdrawal	PASS	src/controllers/authController.js
DELETION_MECHANISM_PRESENT	Section 8 — Data Principal Rights	PASS	src/routes/records.js
DATA_ACCESS_PRESENT	Section 11 — Right to Access	PASS	src/routes/auth.js

30-Day Remediation Roadmap

The following plan prioritises findings by severity and estimated effort. Complete Week 1 items before your next security review.

Week 1 — Critical (1–4 hours)

Fix immediately — these represent the highest legal exposure.

- Grievance Officer Missing (1–4 hrs)

Week 2 — High Priority (4–16 hours)

Address within 2 weeks — short fixes with significant compliance impact.

- Audit Trail Partial (2–8 hrs)
- Incomplete Deletion Coverage (2–8 hrs)

Week 4 — Advisory (4–14 hours)

Address before next compliance review.

- No Breach Alerting (2–6 hrs)
- Data Portability Missing (2–8 hrs)

Total estimated remediation effort: 9–34 hours (1.1–4.2 engineering days)

Changes Since 2026-04-08

— 13 finding(s) unchanged

Details

Finding 1 of 13

[Section 13 — Grievance Redressal]

1. [HIGH] GRIEVANCE_OFFICER_MISSING — N / A

Estimated fix time: 1–4 hours

No compliant Grievance Officer / DPO publication found. A PASS requires grievance-related text or a dedicated route ****and**** a contact email or dedicated grievance/DPO URL. Tiny repos without a grievance route are not marked PASS.

Risk:

The absence of a designated Grievance Officer means individuals have no clear channel to address concerns or complaints regarding their personal data, potentially leading to unresolved issues and a lack of accountability.

Fix:

1. Create a new route (e.g., `/grievance`) that displays contact information for the Grievance Officer.
2. Add a dedicated email address or contact form for grievance submissions.
3. Update the API documentation (e.g., Swagger) to include the new grievance route and contact details.
4. Ensure the Grievance Officer's contact information is clearly published on the company's privacy policy page.

DPDP:

Section 13(1) — requires the appointment and publication of a Grievance Officer to handle data principal complaints.

Example:

```
const express = require('express'); const router = express.Router(); router.get('/grievance',
(req, res) => { res.json({ message: 'For any data protection concerns, please contact our
Grievance Officer.', email: 'grievance.officer@example.com', contact_url: '/contact' }); });
module.exports = router;
```

Finding 2 of 13

[Section 8(4) — Audit Trail]

2. [MEDIUM] AUDIT_TRAIL_PARTIAL — N / A**Estimated fix time:** 2–8 hours

Partial audit trail detected. Found: change tracking. Missing: access logging, audit model.

Risk:

The lack of a comprehensive audit trail, specifically missing access logging and a dedicated audit model, hinders the ability to track who accessed or modified personal data, making it difficult to investigate potential breaches or misuse.

Fix:

1. Implement middleware to log all API requests, including user ID, timestamp, endpoint, and HTTP method.
2. Create a new database table (e.g., `audit\_logs`) to store these access events.
3. Define a clear schema for the `audit\_logs` table, including fields for user, action, timestamp, and relevant data identifiers.
4. Integrate the logging middleware into the main application flow to capture all relevant access.

DPDP:

Section 8(4) — mandates maintaining a record of all processing activities involving personal data, including access and modifications.

Example:

```
const express = require('express'); const router = express.Router(); const pool =
require('../config/database'); // Assuming you have a pool // Middleware to log access
router.use(async (req, res, next) => { const userId = req.user ? req.user.id : null; //
Assuming user is attached to req await pool.query( 'INSERT INTO audit_logs (user_id, action,
timestamp, endpoint) VALUES ($1, $2, NOW(), $3)', [userId, `${req.method} ${req.path}`,
req.path] ); next(); }); // ... other routes ... module.exports = router;
```

Finding 3 of 13

[Section 8 — Data Principal Rights]

3. [MEDIUM] INCOMPLETE_DELETION_COVERAGE — N / A**Estimated fix time:** 2–8 hours

Deletion mechanism detected but may not cover all PII storage. Uncovered files: src/config/database.js. DPDP Section 8 requires complete erasure of all personal data across all systems when a user requests deletion.

Risk:

Incomplete deletion coverage means that personal data might persist in the system even after a deletion request, violating the data principal's right to erasure and potentially leading to non-compliance with data protection regulations.

Fix:

1. Identify all locations where personal data is stored, including database tables, file storage, and any third-party services.
2. Implement a robust 'soft delete' mechanism (e.g., marking records as deleted with a timestamp) across all relevant data stores.
3. Develop a separate, secure process for 'hard deletion' or permanent erasure of data, ensuring it's triggered by user requests.
4. Update the `src/config/database.js` or related data access layers to include deletion logic for any PII managed through it.

DPDP:

Section 8(1) — mandates that data controllers must erase personal data when it is no longer necessary for the purpose it was collected or when consent is withdrawn.

Example:

```
// Example for a hypothetical 'users' table deletion async function deleteUser(userId) { const
client = await pool.connect(); try { await client.query('BEGIN'); // Soft delete user record
await client.query('UPDATE users SET deleted_at = NOW() WHERE id = $1', [userId]); //
Potentially delete related data in other tables await client.query('UPDATE user_profiles SET
deleted_at = NOW() WHERE user_id = $1', [userId]); await client.query('COMMIT'); } catch (e) {
await client.query('ROLLBACK'); throw e; } finally { client.release(); } }
```

Finding 4 of 13

[Section 8(6) — Breach]

4. [LOW] NO_BREACH_ALERTING — N / A**Estimated fix time:** 2–6 hours

Structured logging detected but no breach notification mechanism found. DPDP Section 8(6) requires notifying affected individuals and the Authority without undue delay when a breach occurs. Logging alone is insufficient — implement automated alerting (Sentry, PagerDuty, or equivalent) with escalation to a compliance team.

Risk:

The absence of a data breach alerting mechanism means that the organization cannot promptly notify affected individuals and the relevant authorities in the event of a security incident, increasing the risk of further harm and regulatory penalties.

Fix:

1. Define criteria and thresholds that would trigger a data breach notification.
2. Implement a system or process for detecting potential data breaches (e.g., through security monitoring, anomaly detection).
3. Establish a clear communication plan for notifying affected data principals and the Data Protection Authority.
4. Integrate an alerting mechanism (e.g., email, SMS, internal dashboard) to notify relevant internal stakeholders when a breach is detected.

DPDP:

Section 12(1) — requires data controllers to notify the relevant supervisory authority and data principals of a personal data breach without undue delay.

Example:

```
// Placeholder for a breach detection and alerting function function
detectAndAlertBreach(event) { // Logic to analyze event for potential breach indicators const
isBreach = analyzeSecurityEvent(event); if (isBreach) { console.error('!!! DATA BREACH
DETECTED !!!'); // Trigger notification to internal security team and potentially external
authorities sendNotification('security-team@example.com', 'Data Breach Alert', 'Critical
security incident detected. Immediate investigation required.');// Log breach details for
reporting logBreachDetails(event); } } // Assume analyzeSecurityEvent, sendNotification,
logBreachDetails are defined elsewhere.
```

Finding 5 of 13

[Section 11 — Data Portability]

5. [LOW] DATA_PORTABILITY_MISSING — N / A**Estimated fix time:** 2–8 hours

No data export or portability endpoint detected. DPDP Section 11 requires Data Fiduciaries to provide personal data in a commonly used, machine-readable format upon request.

Risk:

The absence of a data export feature means users cannot exercise their right to obtain their personal data in a usable format, potentially leading to non-compliance with data portability requirements.

Fix:

1. Create a new Express route (e.g., `/api/data-export`) that handles GET requests.
2. Implement authentication and authorization middleware to protect the new endpoint.
3. In the controller for this route, fetch the user's personal data from the database.
4. Format the data into a common machine-readable format (e.g., CSV or JSON) and return it as a file download or JSON response.

DPDP:

Section 11(1) — Data Fiduciaries shall provide personal data in a commonly used, machine-readable format.

Example:

```
const express = require('express'); const router = express.Router(); const { authenticate,
authorize } = require('../middleware/auth'); const dataExportController =
require('../controllers/dataExportController'); // Assume this controller exists // Route to
export user data, accessible by authenticated users router.get('/data-export', authenticate,
authorize('admin', 'analyst'), dataExportController.exportUserData); module.exports = router;
// In src/controllers/dataExportController.js (example): // exports.exportUserData = async
(req, res) => { // const userId = req.user.id; // Assuming user ID is available from auth
middleware // // Fetch user data, format to CSV/JSON, and send as response //
res.status(200).send('Data export initiated'); // };
```

Finding 6 of 13

[Section 7 — Legitimate Use]

6. [INFO] INTERNAL_ROUTE_PII_ACCESS — src / routes / users.js

Internal file (users.js) accesses PII. Verify access is restricted to authorised contexts and PII is not exposed to logs or error responses.

Finding 7 of 13

[Section 5 — Notice]

7. [INFO] NO_THIRD_PARTY_DETECTED — N / A

No known third-party analytics or tracking SDKs detected in codebase.

Finding 8 of 13

[Section 5 — Purpose Limitation]

8. [INFO] NO_THIRD_PARTY_DATA_SHARING — N / A

No third-party data sharing detected.

Finding 9 of 13

[Section 16 — Cross-Border Transfer]

9. [INFO] NO_CROSS_BORDER_DETECTED — N / A

No foreign cloud or non-India region config detected.

Finding 10 of 13

[Section 6 — Consent]

10. [PASS] CONSENT_PRESENT — src / routes / auth.js

Framework auth/consent middleware detected in this file.

Finding 11 of 13

[Section 6(6) — Consent Withdrawal]

11. [PASS] CONSENT_WITHDRAWAL_PRESENT — src / controllers / authController.js

Consent withdrawal mechanism detected. Found in: src/controllers/authController.js (line 74)

Finding 12 of 13

[Section 8 — Data Principal Rights]

12. [PASS] DELETION_MECHANISM_PRESENT — src / routes / records.js

Data deletion mechanism detected. Found 2 deletion endpoint(s) and 7 deletion signal(s). Note: Verify deletion cascades to all PII tables (sessions, logs, related records).

Fix:

1. Verify deletion cascades to: sessions, audit_logs, third-party sync records.
2. Use database CASCADE DELETE or explicit multi-table deletion in deletion service.
3. Test deletion completeness: create account, delete, query all PII tables for orphaned data.

Finding 13 of 13

[Section 11 — Right to Access]

13. [PASS] DATA_ACCESS_PRESENT — src / routes / auth.js

Data access endpoint detected for authenticated users.

AI-Identified Compliance Gaps

The following gaps were identified by AI analysis and cross-validated. These are advisory observations, not verified rule violations. Human review is required before acting on these findings.

[AI-INFERRED] No age verification for user registration

Confidence: 60%

Section 9 — Children

The `POST /api/auth/register` endpoint collects user name, email, and password. There is no logic to verify if the user is a minor before account creation, which is a requirement under Section 9 of DPDP.

Recommendation: Implement age verification logic in ``src/controllers/authController.js`` for the registration endpoint. This could involve asking for date of birth and checking against a minimum age threshold.

[AI-INFERRED] No user data download endpoint

Confidence: 65%

Section 8 Right to Access

The ``data_flows`` indicate that user data is retrieved via ``GET /api/auth/me`` and ``GET /api/users/{id}``. However, there is no explicit endpoint or mechanism described for users to download all their personal data in a portable format, as required by Section 8.

Recommendation: Create a new endpoint, e.g., ``GET /api/users/me/data``, that aggregates all personal data associated with the authenticated user and returns it in a downloadable format (e.g., JSON or CSV).

[AI-INFERRED] Unclear purpose for admin user data access

Confidence: 50%

Section 5 Purpose

The ``GET /api/users`` and ``GET /api/users/{id}`` endpoints retrieve user data (id, name, email, status, role). It is not clear from the ``data_flows`` or code context if these endpoints are for administrative purposes only or if they could be accessed by non-admin users, potentially leading to PII being exposed for purposes not originally consented to.

Recommendation: Review the authorization middleware for ``GET /api/users`` and ``GET /api/users/{id}`` to ensure they are strictly limited to authorized administrative roles. If these endpoints are intended for broader use, clarify the purpose and ensure it aligns with user consent.

[AI-INFERRED] No Data Protection Officer contact exposed

Confidence: 40%

Section 10 DPO

There is no mention of a Data Protection Officer (DPO) or any contact information for a DPO within the provided repository context or ``data_flows``. Section 10 of DPDP typically requires making DPO contact details available.

Recommendation: Add a publicly accessible endpoint or a contact section in the application's UI/API documentation that provides the contact details for the designated Data Protection Officer.